



Individual Data Processing and No-/Low-code Application Governance Guideline

Version: 2.0

Valid From Date: 19.08.2026

Last Review Date: 14.08.2026

Notes: This written rule uses gender-neutral and inclusive language. Whenever possible, the generic masculine is avoided and all employees of any gender identity (m/f/d) are addressed.

Content changes compared to the previous document version are highlighted in color.

Content

1. Purpose, Objectives and Basis	3
1.1. Purpose and Objectives	3
1.2. Basis of this Guideline	3
2. Functional Scope and Target Groups	4
2.1. Functional Scope of applicability	4
2.2. Target groups	4
2.3. Transition period	5
3. Definitions	6
3.1. Requirements	6
3.2. Explanation of requirements and key definitions	7
3.3. IDP applications	7
3.4. No-/Low-Code Applications (NCLC)	9
3.5. IDP allowed runtime environments and script languages	9
4. Requirements	10
4.1. Requirements	10
5. Roles and Responsibilities	18
5.1. Creator	18
5.2. Guideline Owner	18
5.3. IDP Coordinator	18
5.4. IDP Business Support	18
5.5. IDP Developer	19
5.6. IDP Tester	19
5.7. IDP Process Owner	19
5.8. IDP Information Owner	19
6. Appendix	20
6.1. Contact Information	20
6.2. Document History	20
6.3. Related Written Rules	20
6.4. Abbreviations	21

1. Purpose, Objectives and Basis

1.1. Purpose and Objectives

The Individual Data Processing and No-/Low-code Application Governance Guideline (hereinafter "Guideline") establishes control requirements for DBAG and/or adopting Legal Entities within DBG (refers only to Legal Entities that have ratified the Guideline at hand) and provides criteria for fulfilling the control requirements.

The purpose of the Guideline is to effectuate IDP policy and the below listed Minimum Requirements, stipulated in the ICT Risk Management Policy (structured into Core Functions), acting as objectives to the Guideline and the control requirements at hand:

Core Function	Minimum Requirement	ICT Risk Management Policy chapter
Govern	2. Allocate roles and responsibilities as detailed in chapter 5 in the ICT Risk Management Policy.	4.1
Govern	6. Have in place a mechanism to define and document responsibilities for implementing control requirements both within and outside IT and IS (e.g. HR). This can be documented e.g. as part of the ICT Control Framework (former Mandatory Control Framework (MCF)) .	4.1
Identify	2. Identify and record assets (e.g. data, hardware, software, systems, facilities, services, people) including respective interdependencies and classify these assets with their relative importance to organizational objectives and the organizations' risk strategy.	4.2
Learn and evolve	4. Monitor relevant technological developments on a continuous basis to understand the possible impact on its digital operational resilience.	4.7

Table 1: Minimum Requirements

Note: The full list of Core Functions and Minimum Requirements is stipulated in the ICT Risk Management Policy.

This Guideline establishes distinct but aligned governance approaches for Individual Data Processing (IDP) and No-/Low-Code applications. While both domains support business-driven development and may share selected requirements, they are governed under separate scopes and control frameworks to reflect their differing technology characteristics, operating models, and risk profiles.

1.2. Basis of this Guideline

The basis for this Guideline is the **thematically linked ICT Risk Management Policy**.

2. Functional Scope and Target Groups

2.1. Functional Scope of applicability

Entity	DBAG and/or adopting LE within DBG
Area	DBAG CIO / COO Division; Chief Risk Officer Area; or any other area that owns Individual Data Processing and No-/Low-code Applications Governance topic

Table 2: Scope

2.2. Target groups

Within the scope of the current Individual Data Processing and No-/Low-code Application Governance Guideline below is addressed the list of applicable target groups and operation areas¹:

Target group	Key message
ICT Risk Oversight	To define requirements for control implementation and oversee enforcement of control requirements related to data processing and No-/Low-code Applications Governance.
ICT Operational Management	To drive the implementation and operationalization of applicable controls and measures in alignment with ICT Risk Framework
All employees	To ensure compliance and minimize risks.

Table 3: Target groups

¹ For LE Guidelines adoption process the target groups should be adjusted according to organizational structure of the LE.

2.3. Transition period

The grace period for new requirements commences from the “valid from” date stated on the cover page. The compliance dates for control requirements defined in this version of the Guideline are defined as follows:

- For unchanged control requirements and new DORA requirements the compliance date equals the “valid from” date.
- For new and changed control requirements that are more stringent than before and are not subject to DORA, the compliance date is generally 90 calendar days after the “valid from” date unless otherwise stated in brackets after the control requirements. These control requirements are marked with ●.
- For Legal Entities that have not previously approved the IT-related requirements and are therefore addressing these requirements for the first time, a grace period of 90 days may be granted at the discretion of the Legal Entity. DORA requirements are exempt from this grace period.

For a **compliance date** exceeding a 180 calendar days implementation timeline, a Board approval is required.

3. Definitions

3.1. Requirements

Control requirement

The control requirements define the organizational, process or technical controls to be implemented by the control owner to achieve compliance with this Guideline.

Criteria

Criteria define the measures that 'must' or 'should' be taken to fulfill the control requirement.

Level of obligation

With respect to requirements and criteria, the following terms are used to define the level of obligation, provided for the implementation of a particular requirement or criteria:

- **“must”**: Mandatory control requirements / criteria derived directly from law, regulations, or internal specifications that the legal entity must comply with. Incompliance could result in consequences with external regulators and Internal Audit.
- **“should”**: Non-mandatory control requirements / criteria derived from best-practice frameworks or equivalent sources that the legal entity does not have to necessarily comply with. Under specific circumstances there may exist valid reasons to ignore a particular control requirement, but the full implications must be understood and carefully weighed.

Independent of the level of obligation of a given requirement or criteria, it is allowed to deviate from single requirements or criteria in individual cases. However, a control requirement deviation always requires the conduction of a risk assessment and risk management including adequate risk acceptance and/or mitigation.

Any deviation from the Guideline denotes an exemption. The respective **Information** Owner makes decisions on such exemptions. **Information** Owners can only decide on risks with impact exclusively in their area of responsibility.

Responsibilities

The responsibility for fulfilling control requirements may be distributed across the organization, e.g., multiple Sections, Units, or Departments. In some cases, one Unit may be responsible for both the design and implementation of measures. In other cases, one Unit may be responsible for the design of measures, and another Unit may be responsible for the implementation of the measures. In addition, multiple Units may be responsible to collectively fulfill one requirement.

The precise responsibilities are to be defined in the underlying Procedure documents (e.g. via RACI matrices).

The ICS, among its various functionalities, registers Process Operators (PO) and Risk Representatives (RRs) mapped to the corresponding processes, controls, and risks which the RRs and/or POs are responsible for managing on behalf of the part of the organization that utilize their services (e.g. Asset Owners). For more information on ICS, please refer to the DBG ICS Guideline.

3.2. Explanation of requirements and key definitions

Control requirements are defined in a standardized format and are structured into the following components:

<Specify ID: xx (version x)>	<Name of control requirement (e.g. Access to production data)>
1	<Description of the control requirement>
1.1 1.1.1	<Lists the criteria applying to the control requirement> <Lists the sub-criteria applying to the control requirement> Asset-Types: <Lists asset types applicable to the control requirement> Key references: <Lists key regulatory references and industry best practice requirements affecting this control requirement (e.g., ISO/IEC 27001:2022 A.5.10, A.8.1)>

The terms in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

3.3. IDP applications

IDP applications are applications developed by the end user in the business units, which are not the result of an established software development process within IT and where changes or adaptations are not subject to established IT change management processes. IDP applications are part of a business process and are required for operating the business process or for controlling it.

Additionally, the following criteria must be fully met so that an IDP application qualifies as such:

1. The application is based on an approved technology.
2. The application is used regularly and in future, thus applications that are used for one-time events or that are stored for archiving or backups are excluded.
3. The application contains data processing required by a business process. This means that the protection goals integrity, authenticity, or availability are threatened by a faulty data processing². Data processing is, for instance, the use of formulas or programming code. This is to be distinguished from data processing for the purpose of simple visualisation or a small number of simple arithmetic operations, which does not qualify a file as an IDP application.

Deviations

² Relevant data processing in this context refers to IDPs which are required for the operation or control of a business process, and which are furthermore threatened in terms of integrity, authenticity, and/or availability. Therefore, it is independent from an application's confidentiality because this is also controlled by other mechanisms according to the ICT Risk Management Policy.

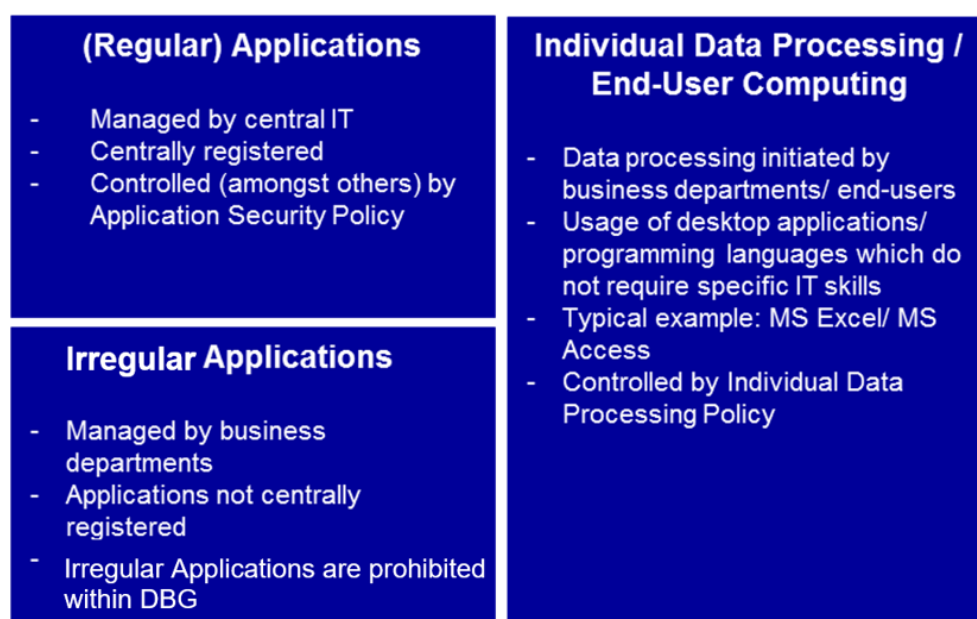
1. Deviating from point 2 are applications developed by the end user in the business units that are used once in a recurring process and that have a direct regulatory or legal relevance (particularly, regarding annual financial statements, tax, risk management, and external reporting). These are to be classified as IDP applications.
2. Deviating from points 2 and 3 are such files that are directly used for external reporting. These are to be classified as IDP applications.

The Senior Management of the Legal Entity may determine business processes to be excluded, substantiated by a justification.

Due to a risk-based approach and the lower protection need of IDP applications of the criticality levels "minor" and "negligible", tiered control requirements are to be applied for these IDP applications.

- **Regular Applications:** Regular Applications are managed by the IT function. The development, maintenance and support follow established IT processes. Information about all regular applications is stored in a central register and the security criticality ratings.
- **Irregular Applications:** Irregular Applications are indifferent from regular applications in terms of e.g. size or complexity but are used exclusively through the business department employing such applications. Due to the lack of central IT process enforcement, security controls are often not implemented on process and technical level. The use of Irregular Applications within DBG is prohibited. Irregular applications existing at the time this policy becomes effective need to (1) be reported to the IT Governance function or senior management immediately, and (2) either be transferred to regular applications or be deactivated.

The following diagram provides an overview of the different types of applications:



3.4. No-/Low-Code Applications (NCLC)³

Applications developed on approved application platforms using no-code and/or low-code capabilities that provide shared, persistent functionality to both support and automate organizational activities and are operated under defined governance. Examples: Power Apps, Power Automate, Power BI.

- Standard No-/Low-Code applications: applications or solutions classified as minor or negligible regarding confidentiality, integrity, availability or authenticity and low technical complexity;
- Extended No-/Low-Code applications: applications or solutions classified as major or critical regarding confidentiality, integrity, availability or authenticity and low technical complexity, or classified as minor or negligible regarding confidentiality, integrity, availability or authenticity but high technical complexity
- Advanced No-/Low-Code application: applications or solutions classified as major or critical regarding confidentiality, integrity, availability or authenticity and high technical complexity.

	Negligible	Minor	Major	Critical
Low technical complexity	Track A - Standard No-code/Low-code apps		Track B - Extended No-code/Low-code apps	
High technical complexity	Track B - Extended No-code/Low-code apps		Track C - Advanced No-code/Low-code apps	

3.5. IDP allowed runtime environments and script languages

The following list reflects all runtime environments, scripting languages, and interpreter on which IDP applications may be based on beside MS Excel and MS Access.

- Python
- R
- SQL
- VBA used MS Excel and MS Access
- Visual Basic

³ No-/Low-Code applications are conceptually distinct from Individual Data Processing (IDP) applications. While certain governance and control requirements may be comparable, No-/Low-Code applications are subject to a separate, dedicated governance framework as defined in this Guideline. The applicability of IDP control requirements to No-/Low-Code applications is limited to explicitly referenced cases and must be applied in a risk-based and proportional manner.

4. Requirements

4.1. Requirements

ID: 1 (version 2.0)	IDP Monitoring & Oversight
1 DOR.ICT.IDP.MNO.001	It must be ensured that IDP control activities are monitored and governed.
1.1 DOR.ICT.IDP.MNO.002	A centralized monitoring and oversight mechanism must be established and maintained to govern and monitor the execution of IDP control activities in DBG • Asset-Types: Information, Business Process, Individual Data Processing Key References: DORA 2022/2554 A.5.1, A6.1, ISO 27001:2022 Cor 202203 A.5.36

ID: 2 (version 2.0)	Individual Data Processing Inventory and Ownership
2 DOR.ICT.IDP.INV.001	All Individual Data Processing applications must be centrally inventoried, regular reviewed, disabled if in-active for over 14 months, and documented.
2.1 DOR.ICT.IDP.INV.002	All Individual Data Processing applications (IDP applications) currently used in practice must be consistently identified and inventoried in a central IDP application Inventory. If the IDP application is not detected through technical measures, it must be registered manually. Asset-Types: Information, Business Process, Individual Data Processing Key References: DORA 2022/2554 A.8.1, DORA RTS RMF A.4.1, ISO 27001:2022 Cor 202203 A.5.9
2.2 DOR.ICT.IDP.INV.003	For all identified IDP applications the IDP application Inventory must contain at least the following information: - name and purpose of the IDP application - version history, date - externally or internally developed - staff member(s) responsible for specialist aspects - staff member(s) responsible for technical aspects - technology (runtime environment or scripting language as chapter 3.3) - tagging of KRITIS-relevant assets • - tagging of CIF supporting assets • - result of the classification/protection requirements classification and, where appropriate, the protective measures derived from these Asset-Types: Information, Individual Data Processing, No-code/Low-code Applications Key References: §8a (1) BSIG 9, 10, DORA 2022/2554 A.8.1, A.8.4, DORA RTS RMF A.4.2, ISO 27001:2022 Cor 202203 A.5.9
2.3 DOR.ICT.IDP.INV.004	For all identified critical and major IDP applications the IDP application Inventory must additionally contain the following information: - Information Owner - Owning LE - Using LE

	Asset-Types: Information, Individual Data Processing, No-code/Low-code Applications Key References: DORA 2022/2554 A.8.1
2.4 DOR.ICT.IDP.INV.005	All IDP applications used in practice must be reviewed at least once a year and the review results must be documented. The review must evaluate: - if the IDP application Inventory is complete and up to date, - if the IDP application information classification is still valid, - if the documentation is sufficient to meet the requirements in this Guideline - if any additional checks are required, depending on special requirements of legal entities. Asset-Types: Individual Data Processing Key References: DORA 2022/2554 A.8.1, A.8.6, ISO 27001:2022 Cor 202203 A.5.9
2.5 DOR.ICT.IDP.INV.006	The IDP application review results must be yearly provided to the Legal Entity IDP Coordinator as well as reported to the respective legal entity boards. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.9
2.6 DOR.ICT.IDP.INV.007	Appropriate control activities must be defined to ensure operationalization of activities. These controls must be reasonably comprehensive and documented to ensure consistency and quality across all legal entities. Asset-Types: Information, Business Process Key References: DORA RTS RMF A.5.1, ISO 27001:2022 Cor 202203 A.5.9
2.7 DOR.ICT.IDP.INV.008	All IDP applications at legal entities must have an IDP Developer and IDP Process Owner. Asset-Types: Individual Data Processing Key References: DORA 2022/2554 A.8.1, ISO 27001:2022 Cor 202203 A.5.9
2.8 DOR.ICT.IDP.INV.009	IDP applications and Standard & Extended No-/Low-code applications (NCLC) which have not been used for more than 14 months must be disabled (180 days) • Asset-Types: Information, Individual Data Processing, No-code/Low-code Applications Key References: DORA RTS RMF A.4.2, ISO 27001:2022 Cor 202203 C.6.1.2

ID: 3 (version 2.0)	Classification of information
3 DOR.ICT.IDP.CLA.001	Individual Data Processing and Standard & Extended NCLC applications must be classified based on their impact on security, technical complexity, and operational requirement, and regularly assessed.
3.1 DOR.ICT.IDP.CLA.002	IDP applications and Standard & Extended NCLC must be classified upon usage in practice according to an established information classification scheme in conformance with the information, which is processed, otherwise handled, or protected by the application, i.e., considering the impact regarding confidentiality, integrity, availability, and authenticity (180 days) • Asset-Types: Information, Individual Data Processing, No-code/Low-code Applications Key References: DORA 2022/2554 A.8.1, DORA RTS RMF A.5.2, ISO 27001:2022 Cor 202203 A.5.12

3.2 DOR.ICT.IDP.CLA.003	A reassessment of the IDP applications and Standard & Extended NCLC classification must be performed on an ad hoc basis in case of changes (180 days) • Asset-Types: Information, Individual Data Processing, No-code/Low-code Applications Key References: DORA 2022/2554 A.8.1, ISO 27001:2022 Cor 202203 A.5.12
3.3 DOR.ICT.IDP.CLA.004	Each Legal Entity must define their relevant processes regarding management of IDP applications. Asset-Types: Information, Business Process Key References: DORA RTS RMF A.17.1 h), ISO 27001:2022 Cor 202203 C.6.1.2
3.4 DOR.ICT.IDP.CLA.005	Each IDP and Standard & Extended NCLC application must be classified regarding the technical complexity before it is used in practice (180 days) • Asset-Types: Information, Individual Data Processing, No-code/Low-code Applications Key References: DORA RTS RMF A.5.2, ISO 27001:2022 Cor 202203 C.6.1.2

ID: 4 (version 2.0)	Development and Documentation of IDPs and Extended No-/Low-Code Apps
4 DOR.ICT.IDP.DEV.001	IDP and Extended No-/Low-Code application development must include a prior review to ensure necessity, adherence to coding standards and required documentation for major and critical applications.
4.1 DOR.ICT.IDP.DEV.002	Before an IDP application of the level "critical" or "major" and Extended NCLC application are newly developed or an application of the level "minor" or "negligible" level will fall into this category due to further development, the respective business unit and IT should jointly verify whether the planned processing purpose and the task addressed by the IDP and Extended NCLC application can already be covered by one of the existing applications or by its further development (180 days) • Asset-Types: Information, Individual Data Processing, No-code/Low-code Applications Key References: DORA 2022/2554 A.9.4 e), ISO 27001:2022 Cor 202203 A.8.27
4.2 DOR.ICT.IDP.DEV.003	IDP and Extended NCLC applications must follow established coding principles (180 days) • Asset-Types: Information, Individual Data Processing, No-code/Low-code Applications Key References: DORA RTS RMF A.9.4 e), DORA RTS RMF A.16.9, ISO 27001:2022 Cor 202203 A.8.31
4.3 DOR.ICT.IDP.DEV.004	For all major and critical IDP and extended NCLC applications regarding authenticity, integrity or availability the development, including a functional documentation, must be documented in a clearly structured way and in a manner that is readily comprehensible for competent third parties. For all major and critical IDPs and Extended NCLC regarding confidentiality a limited functional documentation should be provided. The documentation must be stored according to applicable retention times (180 days) • Asset-Types: Information, Individual Data Processing, No-code/Low-code Applications Key References: DORA 2022/2554 A.9.4 e), DORA RTS RMF A.16.2, ISO 27001:2022 Cor 202203 A.5.8
4.4 DOR.ICT.IDP.DEV.005	For all IDP and Standard & Extended NCLC applications, a technical documentation must be in place (180 days) • Asset-Types: Information, Individual Data Processing, No-code/Low-code Applications Key References: DORA RTS RMF A.9.4 e), DORA RTS RMF A.16.2, MAS TRMG 6.5.3

ID: 5 (version 2.0)	General risk management
5 DOR.ICT.IDP.GRM.001	Monitoring control and processes to manage IT and security risk for major and critical IDP and Extended NCLC applications must be established, including regular and ad-hoc risk assessment, following establishing risk management practice.
5.1 DOR.ICT.IDP.GRM.002	For major and critical IDP and Extended NCLC applications appropriate monitoring and control processes must be set up for IT and information security risks and other relevant risks caused by the application. This includes in particular the definition of risk criteria, the identification of risks, the determination of the need for protection, the derived protective measures for

	IT operations and the definition of appropriate measures for risk handling and mitigation (180 days) • Asset-Types: Business Process, No-code/Low-code Applications Key References: DORA 2022/2554 A.8.2, DORA RTS RMF A.3, A.9.1, ISO 27001:2022 Cor 202203 C.6.1.2
5.2 DOR.ICT.IDP.GRM.003	Risk assessments for major and critical IDP and Extended NCLC applications classified as major, critical regarding confidentiality, authenticity, integrity or availability must be performed regularly and on an ad hoc basis in case of changes of the applications criticality and identified risks must be reported following established information security risk management processes (180 days) • Asset-Types: Business Process, No-code/Low-code Applications Key References: DORA 2022/2554 A.8.3, DORA RTS RMF A.3, ISO 27001:2022 Cor 202203 C.6.1.2

ID: 6 (version 2.0)	IDP Application training
6 DOR.ICT.IDP.TRA.001	It must be ensured that employees are aware of IDP application-related topics.
6.1 DOR.ICT.IDP.TRA.002	IDP application trainings must be performed to increase the employees' awareness regarding IDP application-related topics. Additionally, these trainings should cover external employees to further enhance their understanding. Asset-Types: Business Process Key References: DORA 2022/2554 A.13.6, DORA RTS RMF A.19b), ISO 27001:2022 Cor 202203 C.6.3

ID: 7 (version 2.0)	Technical security measures for IDP and Extended No-/Low-Code Applications
7 DOR.ICT.IDP.SEC.001	Security measures for IDP and Extended NCLC applications must be in place and commensurate with their classification, including documentation, access control, test management, business continuity management, periodic review, and transfer to regular applications.
7.1 DOR.ICT.IDP.SEC.002	The classification of information must determine the protection requirements for IDP and Extended NCLC applications (180 days) • Asset-Types: Information, Individual Data Processing, No-code/Low-code Applications Key References: DORA 2022/2554 A.9.1, ISO 27001:2022 Cor 202203 A.5.8
7.2 DOR.ICT.IDP.SEC.003	If the protection requirements derived from the criticality exceed the technical protection possibilities of the IDP application (e.g., VBA password, file open password), appropriate protective measures must be taken. Asset-Types: Information, Individual Data Processing Key References: DORA 2022/2554 A.9.2, ISO 27001:2022 Cor 202203 C.6.1.3
7.3 DOR.ICT.IDP.SEC.004	To reduce risks regarding authenticity, integrity, or availability, IDP applications classified as critical and Extended NCLC applications classified as critical regarding confidentiality, authenticity, integrity or availability must be transferred into a regular application within three years after classification. A

	decommission plan for the specific replacement must be provided after one year (180 days) • Asset-Types: Individual Data Processing, No-code/Low-code Applications Key References: DORA 2022/2554 A.9.4 c), ISO 27001:2022 Cor 202203 C.6.1.3
7.4 DOR.ICT.IDP.SEC.005	Protection controls for IDP and Extended NCLC applications must follow a risk-based approach, thus demanding more strict control requirements for major and critical IDP and Extended NCLC applications classified as major/critical regarding confidentiality, authenticity, integrity or availability (180 days) • Asset-Types: Information, Business Process, No-code/Low-code Applications Key References: DORA 2022/2554 A.9.1, ISO 27001:2022 Cor 202203 A.5.8
7.5 DOR.ICT.IDP.SEC.006	For minor and negligible IDP with high technical complexity and Extended NCLC applications classified as minor/negligible regarding confidentiality, authenticity, integrity or availability but high technical complexity, test management and access management must be in place (180 days) • Asset-Types: Information, Individual Data Processing, No-code/Low-code Applications Key References: DORA 2022/2554 A.11, DORA RTS RMF A.21, ISO 27001:2022 Cor 202203 A.8.29
7.6 DOR.ICT.IDP.SEC.007	For all major and critical IDPs and Extended NCLC applications classified as major/critical regarding confidentiality, authenticity, integrity or availability, processes must be established for appropriately allocating access rights to ensure that staff have only those rights that they need to perform their tasks. This includes the recertification process for authorizations (180 days) • Asset-Types: Information, Individual Data Processing, No-code/Low-code Applications Key References: DORA 2022/2554 A.9.2, A.9.3, DORA RTS RMF A.21,
7.7 DOR.ICT.IDP.SEC.008	All major and critical IDPs and Extended NCLC applications classified as major/critical regarding confidentiality, authenticity, integrity or availability must be secured against changes to the program logic in production (180 days) • Asset-Types: Individual Data Processing, No-code/Low-code Applications Key References: DORA 2022/2554 A.9.4 e)
7.8 DOR.ICT.IDP.SEC.009	For major and critical IDP with low technical complexity and Extended NCLC applications classified as major/critical regarding confidentiality, authenticity, integrity or availability but a low technical complexity a, test management and access management must be in place (180 days) • Asset-Types: Information, Individual Data Processing, No-code/Low-code Applications Key References: DORA RTS RMF A.16.2, A.21, ISO 27001:2022 Cor 202203 A.8.29
7.9 DOR.ICT.IDP.SEC.009	For major and critical IDP with low technical complexity and Extended NCLC applications classified as major/critical regarding confidentiality, authenticity, integrity or availability but a low technical complexity a, test management and access management must be in place (180 days) • Asset-Types: Information, Individual Data Processing, No-code/Low-code Applications Key References: DORA RTS RMF A.16.2, A.21, ISO 27001:2022 Cor 202203 A.8.29
7.10 DOR.ICT.IDP.SEC.011	The availability of all IDP and Extended NCLC applications must at least be ensured by appropriate recovery mechanisms of the underlying file storage (180 days) • Asset-Types: Information, Individual Data Processing, No-code/Low-code Applications Key References: DORA 2022/2554 A.11.1, A.12.1, DORA RTS RMF A.24, ISO 27001:2022 Cor 202203 A.8.13

7.11 DOR.ICT.IDP.SEC.012	Authorized access to all IDP and Extended NCLC applications must at least be ensured by basic access control mechanisms (180 days) • Asset-Types: Information, Individual Data Processing, No-code/Low-code Applications Key References: DORA 2022/2554 A.9.2, DORA RTS RMF A.20, ISO 27001:2022 Cor 202203 A.5.18
7.12	For IDP with high technical complexity, measures and controls must be established to ensure the segregation of environments, the protection of data processed in non-production environments, the use of anonymized, pseudonymized or randomized data for testing, and the controlled, documented and approved use of production data where exceptionally required (180 days) • Asset-Types: Information, Individual Data Processing Key References: DORA RTS RMF A.16.1, A.16.5, A.16.6, ISO 27001:2022 Cor 202203 C.6.1.3

ID: 8 (version 2.0)	No-/Low-code applications governance
8 DOR.ICT.IDP.NLC.001	No-/Low-code Applications must be governed using a proportional, risk-based approach whereby all components (apps, flows, and environments) comply with ICT Risk Framework and are subject to control requirements commensurate with their business impact and technical complexity.
8.1 DOR.ICT.IDP.NLC.002	Foundational and environmental risk-based protections must be implemented at platform level wherever possible such as DLP (e.g., information/data labelling, connectors restriction), IAM (e.g., identity control, role-based & need-to-know enforcement, SOD (180 days) • Asset-Types: Information, No-code/Low-code Applications Key References: DORA 2022/2554 A.8.1, A.9.1, ISO 27001:2022 Cor 202203 C.6.1.2, C.6.1.3, C.8.2, C.8.3, A.8.4, A.8.19, A.8.25, A.8.29, A.8.31, A.8.32
8.2 DOR.ICT.IDP.NLC.003	Standard and Extended NCLC applications must ensure asset governance (including register centralized inventory, defined ownership, purpose, version history, classification, inventory maintenance, and risk-based periodic review), implement version control and Citizen Developer training must be provided to the users (180 days) • Asset-Types: Information, No-code/Low-code Applications Key References: DORA 2022/2554 A.9.2, ISO 27001:2022 Cor 202203 C.6.1.2, C.6.1.3, C.8.2, C.8.3, A.8.4, A.8.19, A.8.25, A.8.29, A.8.31, A.8.32
8.3 DOR.ICT.IDP.NLC.004	Extended NCLC applications must apply enhanced governance by additionally ensuring that the inventory contains required information as defined in requirement ID 2.2, 2.3, adhering to lifecycle requirements defined in Requirement ID 2.8), implement segregated environment controls (Development / Test / Production) and protect the integrity and confidentiality of data in non-production environments, including the use of anonymized or pseudonymized data, and complying with applicable requirements mentioned in requirement ID 3, 4, 5, 7 where required based on criticality and technical complexity (180 days) •

	Asset-Types: Information, No-code/Low-code Applications Key References: DORA 2022/2554 A.8.1, DORA RTS RMF A.16.9, ISO 27001:2022 Cor 202203 C.6.1.2, C.6.1.3, C.8.2, C.8.3, A.8.4, A.8.19, A.8.25, A.8.29, A.8.31, A.8.32
8.4 DOR.ICT.IDP.NLC.005	Advanced NCLC applications must be governed as regular IT Applications, complying with the applicable set of requirements applicable to regular IT applications, including formal governance, security, and SDLC controls (180 days) • Asset-Types: Information, No-code/Low-code Applications Key References: DORA 2022/2554 A.9.1, DORA 2022/2554 A.9.2, ISO 27001:2022 Cor 202203 C.6.1.2, C.6.1.3, C.8.2, C.8.3, A.8.4, A.8.19, A.8.25, A.8.29, A.8.31, A.8.32

5. Roles and Responsibilities

5.1. Creator

The creator of the Individual Data Processing and No-/Low-Code Applications Governance Guideline is the ICT Risk Governance & Advisory Unit (Specialist).

The creator of the Individual Data Processing and No-/Low-Code Applications Governance Guideline has the responsibility to issue clear, precise, and appropriate written rules to give guidance for implementation to the target group. It is important to ensure that all required information is accurate, up to date and complete.

5.2. Guideline Owner

The owner of the Individual Data Processing and No-/Low-Code Applications Governance Guideline is Head of ICT Risk Governance & Advisory Unit.

The most important tasks (not an exhaustive list) within the scope of responsibility are:

- Ensure completeness of the Guideline within functional area of responsibility
- Ensure correctness of content and the Guideline is up to date
- Define and conduct adherence oversight measures for Guidelines on a regular basis
- Assess impact on the Guideline with major focus on requirements as well as roles and responsibilities in the event of organizational changes, new products etc.

The Guideline Owner has at least an Expert or Head of Unit level.

The Guideline Owner is responsible for publishing and updating the Individual Data Processing and No-/Low-Code Applications Governance Guideline according to established procedures within the organization.

5.3. IDP Coordinator

The IDP Coordinator role is responsible to coordinate the IDP processes within a given Legal Entity, or within several Legal Entities in case of DBAG coordinators (with exceptions) and facilitates that the tools provided by IDP Business Support are used coherently for identifying, inventorying, classifying, and assessing of IDPs of the Legal Entity. If considered useful by a Legal Entity the IDP Coordinator(s) may be made responsible for carrying out controls to ensure compliance with this policy. In such cases the IDP Coordinator(s) is/are explicitly mandated by the Executive Board of the respective Legal Entity to establish and perform such controls. Otherwise, the above-mentioned responsibilities remain with the IDP Process Owner. All Legal Entities must have an IDP Coordinator.

5.4. IDP Business Support

The IDP Business Support is located within Deutsche Börse AG and provides central services to all IDP Coordinators in DBG, and where necessary to all IDP Process Owners in legal entities, constituting tools that support in identifying, inventorying, classifying and assessing of IDP applications. IDP Business Support provides a self-service reporting solution and collects change requirements of the IDP Coordinators for the supporting tools.

Internal

As part of the role assignment the IDP Business Support assumes the following responsibilities for all Legal Entities in scope of the IDP Policy:

- establish the control catalogue for documenting the control activities which must be performed by the responsible 1st LoD role holders;
- act as support function for all IDP Coordinators of the legal entities to address questions regarding the execution of 1st LoD control activities; establish and maintain the IDP Procedure.

5.5. IDP Developer

An IDP Developer is an employee who develops and maintains IDP applications and who provides user support for his IDP applications. It is the responsibility of the IDP Developer to initially perform the protection requirements analysis for the IDP he/she developed.

5.6. IDP Tester

An IDP Tester is an employee who tests IDP applications as part of the test and release process. IDP Tester and IDP Developer must be different persons.

5.7. IDP Process Owner

An IDP Process Owner – as the owner of the IDP application – is the responsible manager (at least Level 4) of the IDP application. The IDP Process Owner is responsible for the classification of IDP applications, their regular review, to ensure risk assessments are executed regularly (for IDP applications with higher criticality), to ensure that the IDP application Inventory is complete and up to date and to approve those IDP applications that require an approval. Otherwise, they are not allowed to be used. In case the approval is delegated, the delegation must be documented in a traceable manner. Furthermore, the IDP Process Owner is responsible that the IDP application meets all requirements defined in the IDP Guideline.

5.8. IDP Information Owner

An IDP Information Owner is responsible for managing risks resulting from IDP applications within his Legal Entity. This includes addressing and mitigating the respective risks. The IDP Information Owner may be identical to the general Information Owner in case a Legal Entity assigns this role to an Information Owner.

6. Appendix

6.1. Contact Information

Written Rule Owner: Head of ICT Risk Governance & Advisory Unit

Please contact ICT Risk Governance & Advisory in case of any questions related to this Guideline.

6.2. Document History

Document History

Version	Date	Changes & Background
1.0	17.01.2025	Initial set-up of this Guideline
1.1	15.08.2025	Annual Update Guideline
2.0	19.08.2026	Annual update with material changes

Coordination before publication

Version	Date	Task	Name
2.0	05.06.2026	Creator	ICT Risk Governance & Advisory Unit (Specialist)
	22.07.2026	Content Review	LE CISOs TISOs IT Ameli project
	22.07.2026	Content Confirmation	Head of ICT Risk Governance & Advisory Unit and LE CISOs

Approvals

Version	Date	Task	Name
2.0	13.08.2026	Approval	DBAG Chief Risk Officer

6.3. Related Written Rules

Superordinated Written Rules	ICT Risk Management Policy
Subordinated Written Rules	IDP Procedure

6.4. Abbreviations

The abbreviations in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

***** END OF DOCUMENT *****
